INTRODUCCIÓN A LA FORENSIA DIGITAL

EXPLICACIÓN PRÁCTICA 2

TEMAS

- PGP

PGP (PRETTY GOOD PRIVACY)

- PGP (Pretty Good Privacy) es un conjunto de programas creados por Phil Zimerman para proteger la información. Es un criptosistema híbrido que utiliza criptografía de clave pública o asimétrica, criptografía simétrica y funciones de hash.
- Al convertirse en uno de los mecanismos más populares para utilizar criptografía, la IETF tomó como base su diseño para crear el estándar OpenPGP.
- Además de proteger los datos en tránsito también permite proteger los datos almacenados en discos, copias de seguridad, etc.

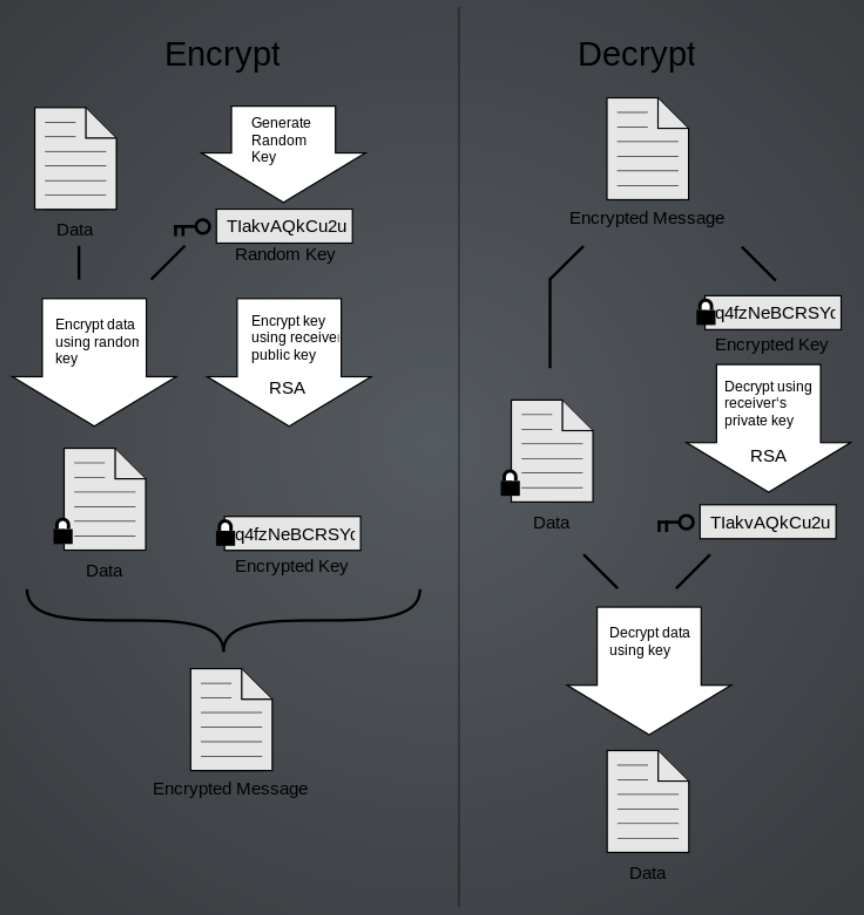
PGP VS OPENPGP VS GNUPG

- PGP: Actualmente propiedad de Symantec.
- OpenPGP: Estándar aprobado por el IETF (RFC 4880) que describe cualquier mecanismo de cifrado que use procesos interoperables con PGP
- GnuPG: Solución que sigue los estándares de OpenPGP desarrollada por la Free Software Fundation

PGP - CLAVES

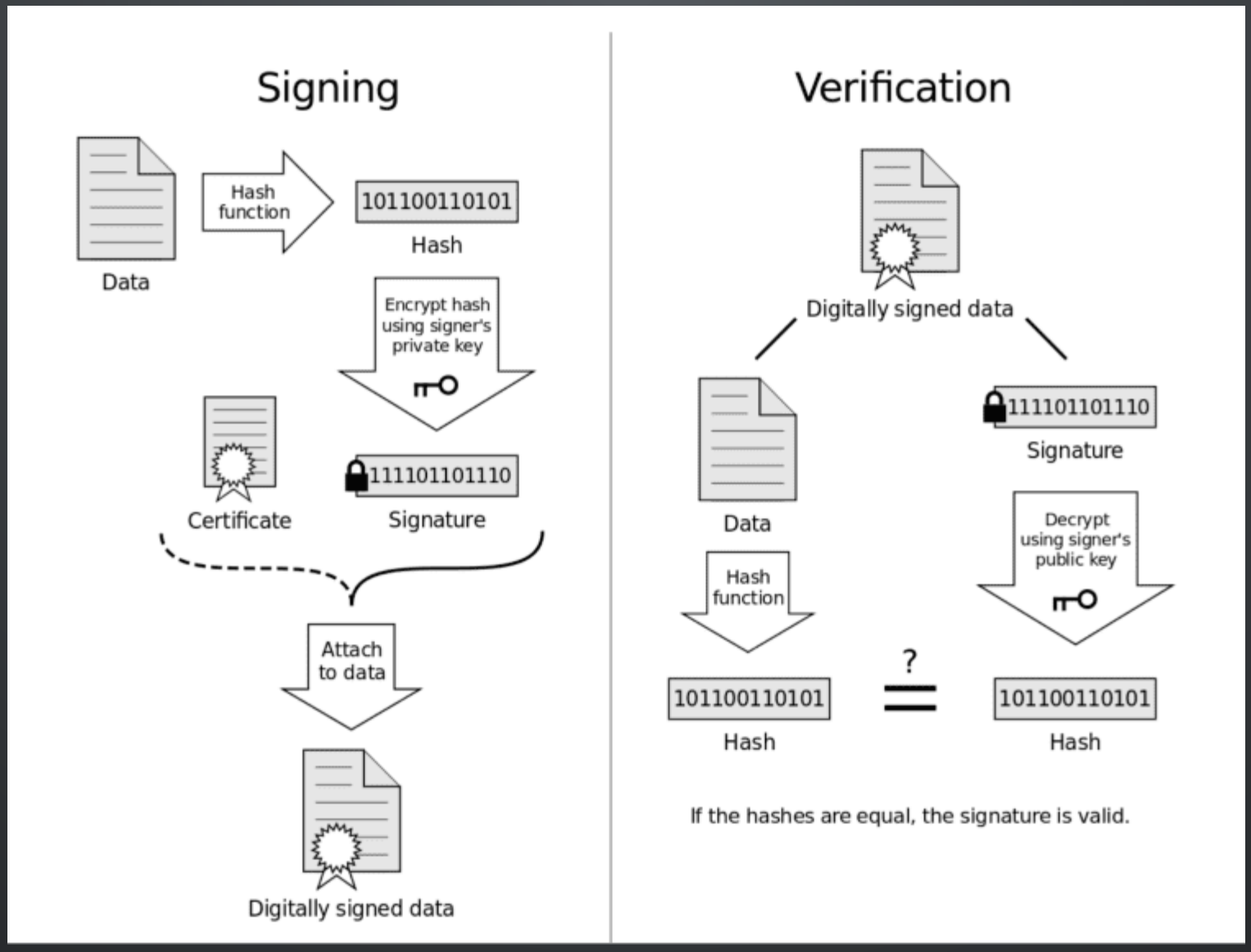
- En PGP, cada usuario genera un par de claves pública/privada.
- La clave pública es la que se puede compartir
- La clave privada nunca debe ser compartida
- Cada clave desencripta un mensaje que fue encriptado con la otra.

PGP - CLAVES PARA CIFRADO



- La clave privada contendrá el header "PGP PRIVATE KEY BLOCK"

PGP - FIRMA


Signing
Data
Hash function
101100110101
Hash
Encrypt hash using signer's private key
Certificate
111101101110
Signature
Attach to data
Digitally signed data
Verification
Digitally signed data
Data
111101101110
Signature
Hash function
Decrypt using signer's public key
101100110101
Hash
?
101100110101
Hash
If the hashes are equal, the signature is valid.

PGP - FINGERPRINT (RFC 4880 - SECTION 12.2)

- Las claves PGP tienen un fingerprint asociado, que básicamente es una versión corta.
- Las «huellas digitales» sirven para confirmar la identidad de la persona.

PGP - CERTIFICADO DE REVOCACIÓN

- Una vez generado el par de claves, es recomendado generar un certificado de revocación que podrá ser utilizado en caso que la clave privada haya sido filtrada.
- Ante la presunción del leak de la clave, se debe subir el certificado de revocación a los servidores de claves para informar que la clave no es más válida.
- Almacenar de forma segura este certificado es tan importante como el resguardo de la clave privada.

PGP - SERVIDORES DE CLAVES

- Los servidores de claves son repositorios utilizados para compartir las claves públicas.
- Es importante remarcar que cualquiera puede generar y distribuir claves para cualquier nombre y dirección de correo.
- El servidor más conocido es el que mantiene el MIT (https://pgp.mit.edu/), pero todos se encuentran sincronizados.

PGP - CIFRADO VS FIRMA

- Cuando se encripta un mensaje o un archivo, se aumenta el nivel de confidencialidad.
- Cuando se firma, se aumenta el nivel de integridad y autenticidad.
- Un mensaje puede ser cifrado y/o firmado.

PGP - RED DE CONFIANZA

Una red de confianza es un concepto utilizado para establecer qué tan confiable es un par de claves que se genera en un esquema descentralizado.

PGP - ANILLOS DE CLAVES

- Anillo de claves públicas: Archivo en el que se guardan las claves públicas del usuario propietario y las claves públicas importadas
- Anillo de claves privadas: archivos en el que se guardan la/s clave/s privada/s del usuario propietario

PGP - ANILLOS DE CLAVES

- Si podemos confirmar la persona que utiliza una clave en particular, podemos firmar dicha clave con nuestra clave privada. Esto permitirá:
- Certificar que dicha clave efectivamente pertenece a esa persona
- Evitar la manipulación de nuestro anillo de claves por parte de un tercero
- Al igual que las claves públicas,las firmas realizadas a una clave también se pueden subir.
- Las reuniones donde se validan, intercambian y se firman claves se las conoce como PGP Parties.

PGP - ESQUEMA DE CONFIANZA

- La confianza es algo subjetivo
- Yo puedo confiar en la clave de una persona, pero no confiar en las claves en las que esa persona confía
- Se pueden establecer relaciones de confianza indirectas.

¿CÓMO USAR PGP?

- Generar par de Claves (Pública/Privada)
- Configurar Cliente de Correo por ejemplo Thunderbird.
- Resguardar la clave privada adecuadamente
- Intercambiar con el circulo de confianza la clave pública. PGP-partys.
- Incorporar claves públicas de terceros a tu llavero -> Fingerprint

Ver: http://pgp.mit.edu/

¿CÓMO USAR PGP?

- Incorporará en sus llaveros las clave públicas de la cátedra:
- einar@mail.info.unlp.edu.ar -> PGP Fingerprint = 699b5cd94c6619bcdce6893de4edc0703db4692e
- sandrazilla@gmail.com → PGP Fingerprint = E20A4D40B8896B9F7B41C8678F1DB90B6B8F9DD4
- Enviar el mail con la conformación del grupo cifrado y firmado a ambos emails

PGP - VENTAJAS

- Su fuerte radica en la facilidad para generar claves y gestionarlas, con un amplio campo de aplicación:
- Comunicación entre individuos en correo electrónico.
- Cifrado de archivos y mensajes.
- Existen versiones libres y comerciales que implementan PGP, para manejo de claves y operaciones de criptografía, las cuales están disponibles para gran variedad de plataformas.
- Basado en algoritmos extensamente revisados y considerados ampliamente seguros (RSA, DSS y Diffie-Hellman; CAST-128, IDEA y 3DES; SHA-1)

PGP - VENTAJAS

- El software y la documentación están disponibles en Internet
- Existen versiones comerciales y libres que implementan los servidores de clave PGP
- No fue desarrollado por ningún gobierno ni organización de creación de estándares, lo cual lo hace atractivo.

PGP - DESVENTAJAS

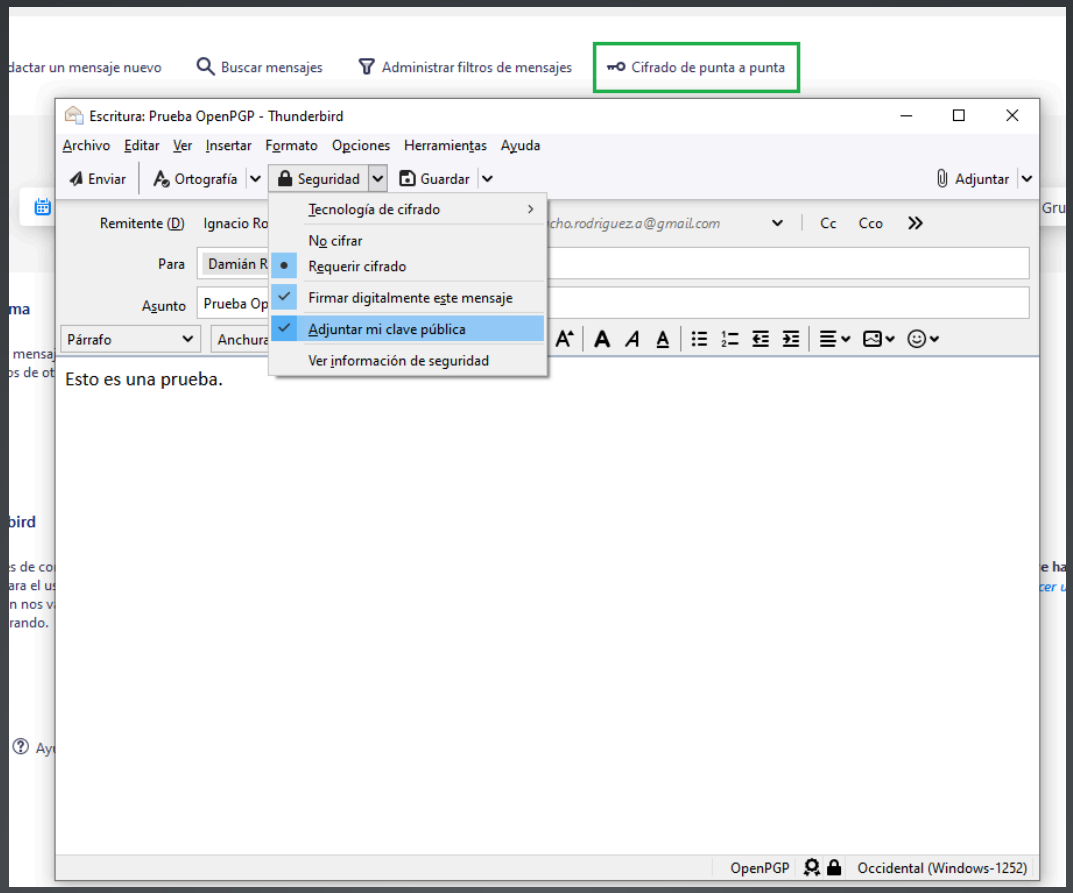
- La gestión de claves en PGP se basa en la confianza mutua: !Los amigos de tus amigos son mis amigos!
- En un sistema abierto en Internet como el comercio electrónico, esta situación y otras más que pueden darse en este sistema de gestión de claves de confianza mutua, resulta inaceptable.

PGP - APLICACIONES

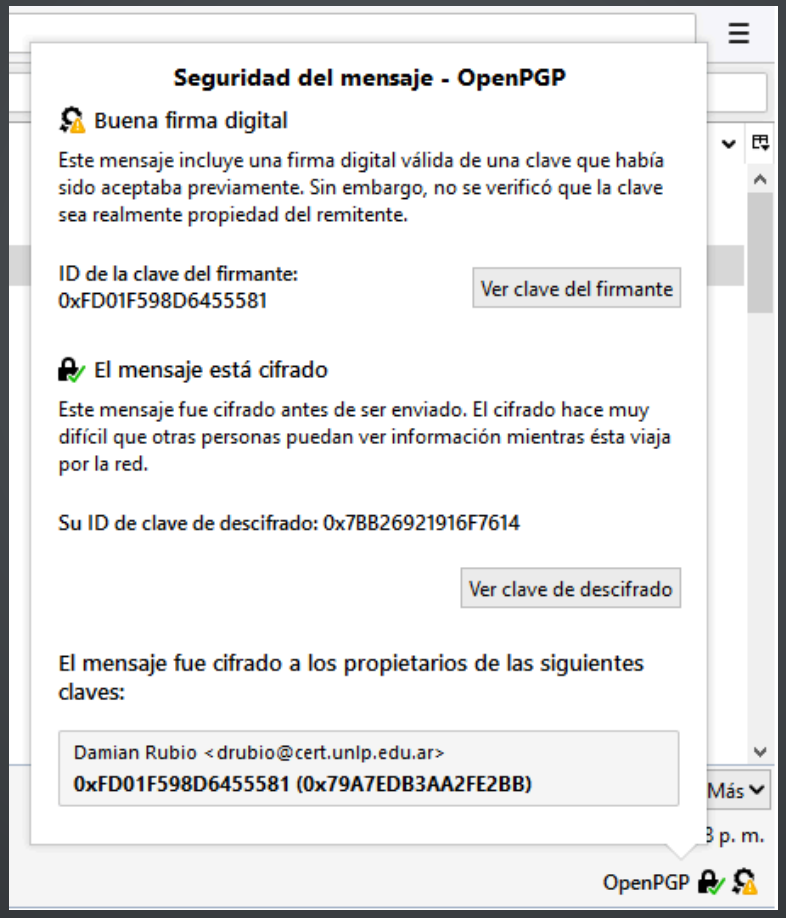
- Correo electrónico
- Thunderbird
- IPGMail para IOS
- K-9 Mail para Android
- Gmail mediante extensión para Google Chrome (FlowCrypt)
- https://www.openpgp.org/software/
- Firma de código (GitHub)
- Cifrado de archivos / disco (gpg4win)

PGP - THUNDERBIRD ENVIAR CORREO CIFRADO Y FIRMADO

Pueden configurar PGP en el botón "Cifrado de punta a punta":



PGP - THUNDERBIRD RECIBIR CORREO CIFRADO Y FIRMADO



PGP Y Y TRIANGULO CIA

- ¿Qué protejo si firmo un mail con mi clave privada?
-

PGP Y Y TRIANGULO CIA

- ¿Qué protejo si firmo un mail con mi clave privada?
  - ASEGURO INTEGRIDAD
-

PGP Y Y TRIANGULO CIA

- ¿Qué protejo si firmo un mail con mi clave privada?
  - ASEGURO INTEGRIDAD
- El mensaje no se puede alterar ya que la firma no coincide y nadie lo puede escribir originalmente,excepto el dueño de la privada

PGP Y Y TRIANGULO CIA

- ¿Qué protejo si encripto un mensaje con la clave pública del destinatario?

-

PGP Y Y TRIANGULO CIA

- ¿Qué protejo si encripto un mensaje con la clave pública del destinatario?
  - ASEGURO CONFIDENCIALIDAD
-

PGP Y Y TRIANGULO CIA

- ¿Qué protejo si encripto un mensaje con la clave pública del destinatario?
  - ASEGURO CONFIDENCIALIDAD
- Nadie puede leer el mensaje, excepto el dueño de la clave privada que se corresponde con la pública utilizada

PGP Y Y TRIANGULO CIA

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. ¿Qué protejo si hago los dos?

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. ¿Qué protejo si hago los dos?
    - ASEGURO INTEGRIDAD y CONFIDENCIALIDAD

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. ¿Qué sucede si el destinatario pierde su clave privada?

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. ¿Qué sucede si el destinatario pierde su clave privada?
    - SE PIERDE DISPONIBIDAD

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. **¿Qué ocurre si en vez de perderse alguien se roba la clave privada del emisor o destinatario?**

PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. **¿Qué ocurre si en vez de perderse alguien se roba la clave privada del emisor o destinatario?**
   - Con la del emisor -> SE PIERDE INTEGRIDAD

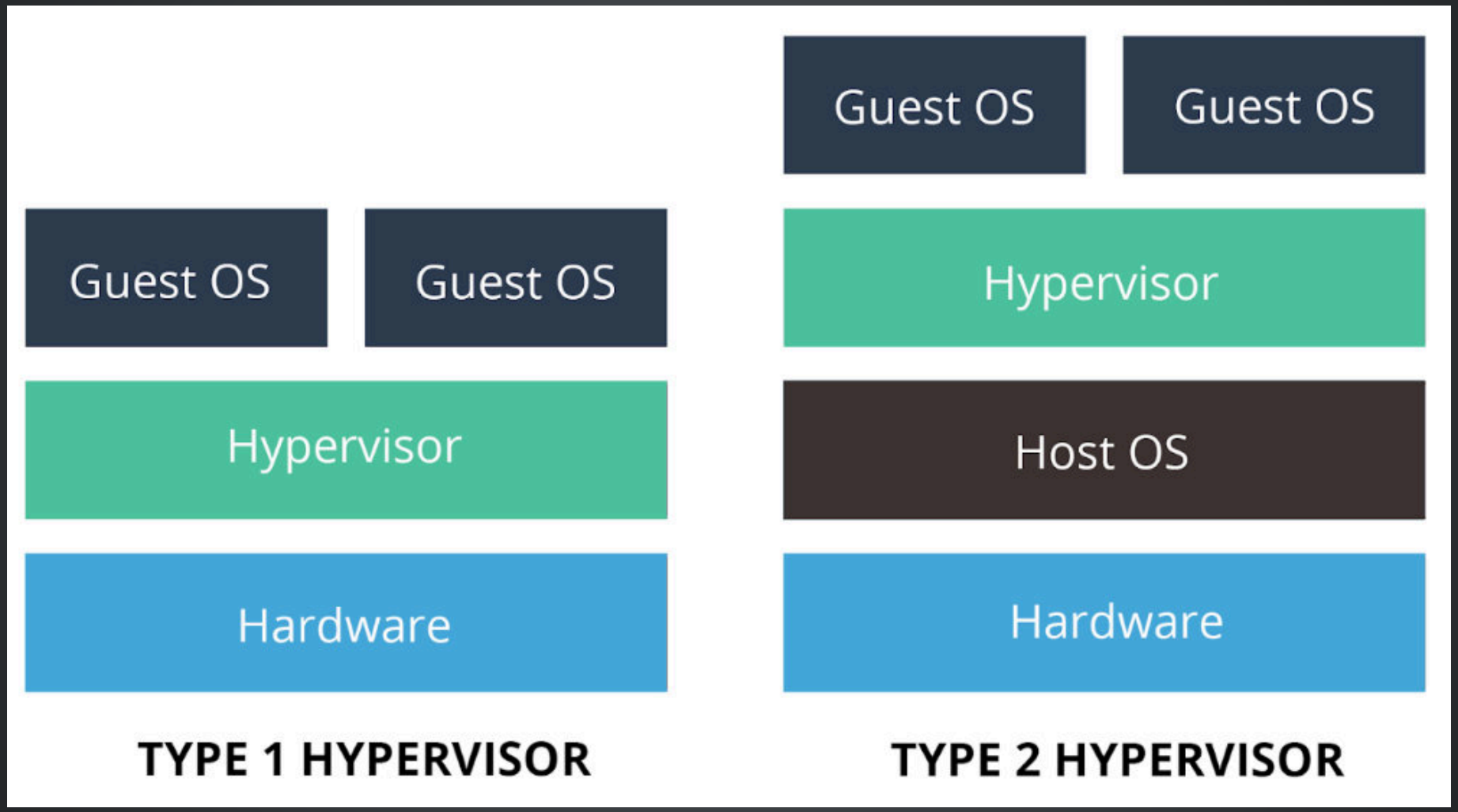
PGP Y Y TRIANGULO CIA

1. Si firmo un mail con mi clave privada
2. Si encripto un mail con la clave pública del destinatario
3. **¿Qué ocurre si en vez de perderse alguien se roba la clave privada del emisor o destinatario?**
   - Con la del emisor -> SE PIERDE INTEGRIDAD
   - Con la del destinatario -> SE PIERDE CONFIDENCIALIDAD

MÁQUINAS VIRTUALES - HIPERVISOR

- También conocido como monitor de máquina virtual, es un proceso que crea y ejecuta máquinas virtuales (VM).
- Es una capa de software para realizar una virtualización de hardware que permite utilizar, al mismo tiempo, diferentes sistemas operativos en una misma computadora.
- Permite que una computadora host admita varias máquinas virtuales invitadas (guest) al compartir virtualmente sus recursos, como la memoria y el procesamiento.
- En general, hay dos tipos de hipervisores:
  - Los hipervisores de tipo 1, llamados "bare metal", se ejecutan directamente en el hardware del host.
  - Los hipervisores de tipo 2, llamados "alojados", se ejecutan como una capa de software en un sistema operativo, como otros programas de computadora.

MÁQUINAS VIRTUALES - GRÁFICAMENTE



MÁQUINAS VIRTUALES - VMWARE

- VMware Inc., es una filial de EMC Corporation (propiedad a su vez de Dell Inc) que proporciona software de virtualización disponible para ordenadores compatibles X86.
- Tiene alternativas de hypervisor tipo 1 y 2.
- Principalmente comerciales
- Muy elegida para ambientes empresariales.

Web: https://www.vmware.com

MÁQUINAS VIRTUALES - VIRTUALBOX

- Virtualbox es un virtualizador mantenido por Oracle para arquitecturas x86 y AMD64/Intel64.
- Corre en Windows, Linux, Macintosh y Solaris.
- Y se puede correr sobre él casi todo!

Web: https://www.virtualbox.org

MÁQUINAS VIRTUALES - VIRTUALBOX

Oracle VM VirtualBox Administrador

Archivo Máquina Ayuda

Herramientas

forensia
Apagada

Windows-Server2012-R2-Standard
Guardada

Nueva Configuración Descartar Iniciar

General

Nombre: forensia
Sistema operativo: Debian (64-bit)

Sistema

Memoria base: 2048 MB
Orden de arranque: Disquete, Óptica, Disco duro
Aceleración: VT-x/AMD-V, Paginación anidada, Paravirtualización KVM

Pantalla

Memoria de vídeo: 12 MB
Controlador gráfico: VBoxVGA
Servidor de escritorio remoto: Inhabilitado
Grabación: Inhabilitado

Previsualización

forensia

Almacenamiento

Controlador: IDE
Controlador: SATA
Puerto SATA 0: forensiaLinux-disk001.vmdk (Normal, 8,00 GB)

Audio

Controlador de anfitrión: Windows DirectSound
Controlador: ICH AC97

Red

Inhabilitado

USB

Controlador USB: OHCI
Filtros de dispositivos: 0 (0 activo)

Carpetas compartidas

Ninguno

Descripción

Ninguno

CONCEPTOS Y HERRAMIENTAS: CONTENEDORES

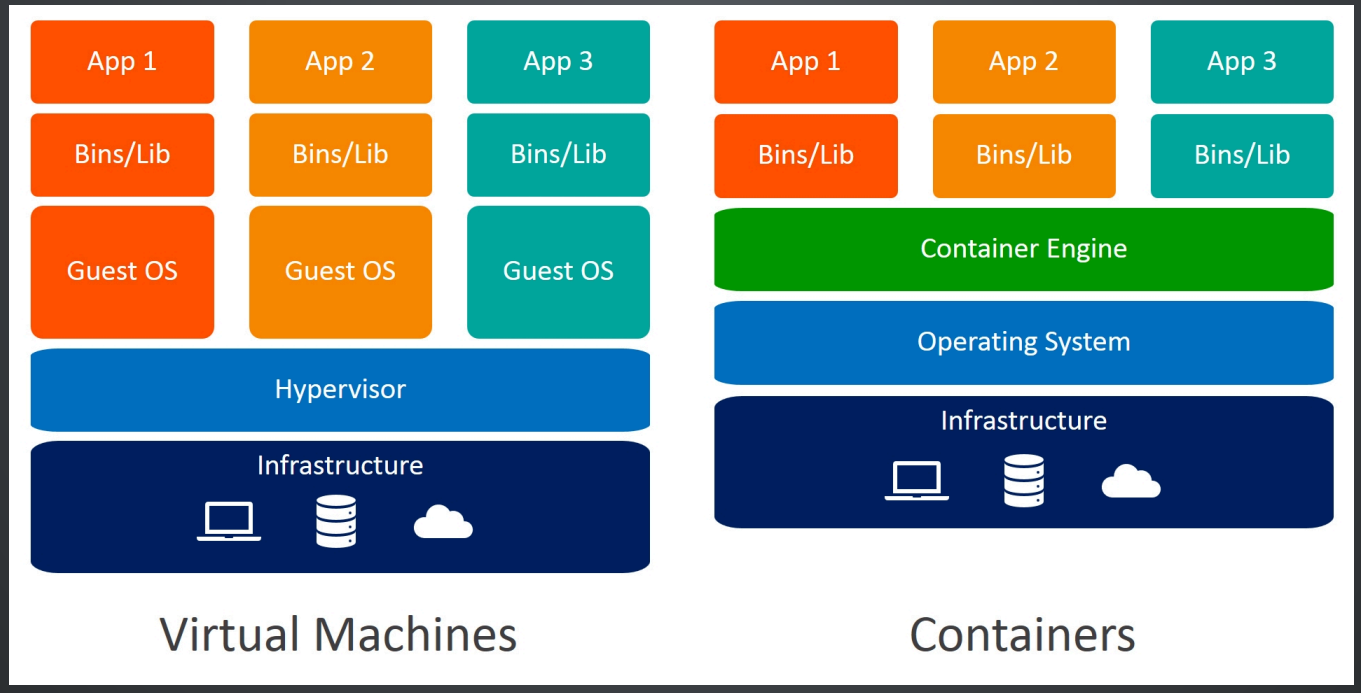
- Utilizando una analogía con el mundo real podemos hablar de esos containers que vemos siendo transportados en barco de un sitio a otro.
- No nos importa su contenido sino su forma modular para ser almacenados y transportados como cajas.

CONTENEDORES

- Algo parecido ocurre con los contenedores software.
- Dentro de ellos podemos alojar todas las dependencias que nuestra aplicación necesite para ser ejecutada:
  - Empezando por el propio código, las librerías del sistema, el entorno de ejecución o cualquier tipo de configuración.
  - Desde fuera del contenedor no necesitamos mucho más. Dentro están aislados para ser ejecutados en cualquier lugar.

CONTENEDORES

- En lugar de virtualizar la pila de hardware como en el enfoque de las máquinas virtuales, los contenedores realizan la virtualización en el nivel del sistema operativo, con varios contenedores que se ejecutan directamente en el kernel del SO.
- Esto significa que los contenedores son mucho más livianos: comparten el kernel del SO, se inician con bastante más rapidez y usan una fracción de la memoria en comparación con el arranque de todo el SO.



CONTENEDORES VS VMS

- Las VMs contienen un sistema operativo completo y sus aplicaciones. La virtualización basada en Hypervisores consume muchos recursos, ya que al tener cada VM su propio sistema operativo, pueden ser muy pesadas.
- Las VMs usan los hypervisores para compartir y manejar el hardware, mientras que los contenedores lo hacen a a través del Kernel del sistema operativo del host.
- Las VM tienen su propio Kernel, no comparten el del host y por lo tanto tienen un mayor poder de aislamiento.

CONTENEDORES VS VMS

- Las VMs que están en el mismo server pueden correr distintos sistemas operativos, una podría correr Ubuntu y otra Windows.
- Los contenedores están atados al kernel de la máquina host, por lo que deben correr un sistema compatible con él.
- Es decir que los contenedores virtualizan el sistema operativo del host mientras que las VMS lo hacen con el hardware del servidor.

CONTENEDORES: HISTORIA

- La idea de lo que ahora llamamos "tecnología de contenedores" surgió por primera vez en el año 2000 como FreeBSD jail, una tecnología que permite la partición de un sistema FreeBSD en varios subsistemas o "jaulas" (jails).
- Las jaulas se desarrollaron como entornos seguros que un administrador de sistemas podía compartir con distintos usuarios dentro o fuera de una empresa.

CONTENEDORES: HISTORIA

- En 2001, se introdujo en Linux la implementación de un entorno aislado, a través del proyecto VServer.
- Una vez que se estableció para múltiples espacios de usuario controlados en Linux, comenzó a tomar forma lo que hoy es un contenedor de Linux (LXC).

CONTENEDORES: HISTORIA

- En 2008, Docker apareció en escena con su tecnología de contenedores que lleva el mismo nombre.
- La tecnología Docker incorporó una serie de conceptos y herramientas nuevos:
  - una interfaz de línea de comandos sencilla para ejecutar
  - diseñar imágenes nuevas en capas
  - un daemon de servidor
  - una biblioteca de imágenes en contenedores prediseñadas (DockerHub)
- Estas tecnologías combinadas permitieron que los usuarios diseñaran rápidamente nuevos contenedores en capas y los compartieran con otros sin ninguna dificultad.

DOCKER

- Las imágenes de los contenedores se convierten en contenedores en el tiempo de ejecución y, en el caso de los contenedores Docker, las imágenes se convierten en contenedores cuando se ejecutan en Docker Engine.
- El software en el contenedor siempre se ejecutará de la misma manera, independientemente de la infraestructura.
- Los contenedores aíslan el software de su entorno y garantizan que funcione de manera uniforme a pesar de las diferencias, por ejemplo, entre el ambiente de desarrollo y el de testing.

DOCKER: IMAGES

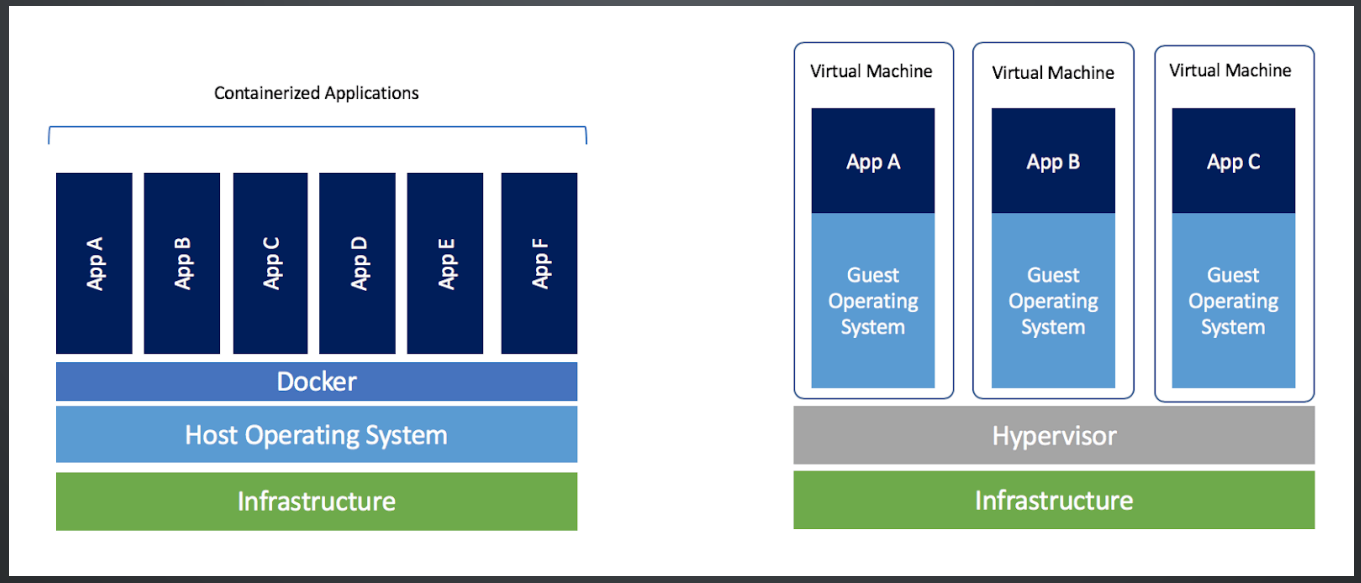
- Una imagen es una especie de plantilla, una captura del estado de un contenedor.
- Las imágenes se utilizan para crear contenedores, y nunca cambian.
- Las imágenes pueden crearse localmente con un DockerFile o descargarlas de DockerHub

Docker: DockerFile

- Es un archivo de configuración que se utiliza para crear
- En dicho archivo indicamos qué es lo que queremos qu
  los distintos comandos para instalar las herramientas.
- https://github.com/CERTUNLP/NgenBundle/blob/mas
  build/base/Dockerfile
- https://github.com/CERTUNLP/NgenBundle/blob/mas
  build/dev/Dockerfile

DOCKER: CONTAINERS

- Son instancias en ejecución de una imagen. Son los que ejecutan cosas, los que ejecutarán nuestra aplicación.
- El concepto de contenedor es como si restauráramos una máquina virtual a partir de un snapshot.
- A partir de una única imagen, podemos ejecutar varios contenedores.



DOCKER: VOLUMES

- No es una buena práctica guardar los datos persistentes dentro de un contenedor de Docker.
- Para eso están los volúmenes, fuera de los contenedores.
- Así podremos crear y borrar contenedores sin preocuparnos por que se borren los datos.
- Además los volúmenes se utilizan para compartir datos entre contenedores.
- Concepto analogo a las carpetas compartidas en VMs.

DOCKER: CORRER UNA IMAGEN DE KALI LINUX

```
sudo apt install x11-xserver-utils
xhost +
docker run --rm --network host -e DISPLAY=$DISPLAY -it -v /tmp/.X11-unix:/tmp/.X
```

DOCKER: LINKS

- Sirve para enlazar contenedores entre sí (que estén dentro de una misma máquina), sin exponer a los contenedores cuáles son los datos de la máquina que los contiene.

DOCKER-COMPOSE

- Docker Compose es una herramienta que permite simp
Docker.
- A partir de archivos YAML es mas sencillo crear conten
habilitar puertos, volumenes, etc.
- Un ejemplo podría ser NGEN
https://github.com/CERTUNLP/NgenBundle/blob/mas
compose.yml
- `docker-compose -f ARCHIVO_YAML_CONFIG [
stop]`

DOCKER: CORRER UNA IMAGEN DE AUTOPSY (TOOLKIT FORENSE)

Demo en https://github.com/digitalsleuth/autopsy-docker

CONCEPTOS Y HERRAMIENTAS: KALI

- Kali es una distribución de GNU/Linux basada en Debian que utiliza Gnome como gestor gráfico
- Esta orientada a pentesting, trayendo preinstaladas muchas de las herramientas que utilizaremos en el curso
- Se distribuye libremente desde https://www.kali.org/downloads/
- Descargar la versión que se corresponda con el sistema operativo que usted tiene (32 o 64 bits)

LABORATORIO FORENSE

- Aspectos de interés
- Herramientas de trabajo
- Costos

¿PREGUNTAS?